

SPOTIFY'S DATA & AI GOVERNANCE PROJECT

3. Data & AI Governance Implementation Plan

Nicolas Pichon - AIA RNCP 38777 / BC01 / Step 3 / v14 - 2026/10/13.

3.1. Objectifs

Ce document présente un plan d'implémentation partielle de la gouvernance des données et des modèles dans le cadre du projet de gouvernance *Spotify*. Le plan proposé est motivé par les objectifs suivants :

- 1. Outiller les rôles opérationnels - *Data Steward, Data Custodian, Model Owner, Model Risk Manager* - de moyens techniques adaptés de leurs responsabilités ;
- 2. Établir une source unique de vérité et un catalogue commun ;
- 3. Valider la viabilité du modèle organisationnel et des outils retenus sur un périmètre limité avant généralisation à l'ensemble de l'organisation ;
- 4. Elever les niveaux de maturité jusqu'au niveau 3, en priorisant les dimensions *Data Governance, Data Quality, Compliance* et *Data Security*

3.3. Modèle organisationnel

Le modèle d'organisation dit "*Center of Excellence*" (*CoE*) formalise l'organisation de la gouvernance des données et des modèles déjà structurée dans [D22] à quelques nuances près.

CoE combine normalement un centre de compétences qui regroupe l'autorité de gouvernance et les services techniques partagés avec des départements de métier partiellement autonomes qui conservent la responsabilité opérationnelle de leurs données. L'implémentation [D22] s'écarte du modèle canonique sur ces deux points : 1) en maintenant l'infrastructure et les compétences techniques dans le département *Engineering* ; 2) en séparant l'autorité de conformité (représentée par les rôles *DPO* et *Legal Team*) de l'autorité de gouvernance (représentée par les rôles *CDO* et *DGC*).

3.4. Outils

Chaque outil équipe un rôle précis du modèle *CoE* et répond à un enjeu identifié en [D1]. La sélection suivante résulte d'une comparaison des outils recommandés dans [R8] avec des alternatives *open source*.

Catégorie	Sous-catégorie	Outil	Opérateurs	Enjeux	Licence
Catalogage	Glossaire & Workflows	Collibra [R8]	DS, DO	E1, E3	Propriétaire
Catalogage	Inventaire & lineage	OpenMetadata	DC	E1	Apache 2.0
Qualité	Contrôle courant & datasets d'entraînement	Soda Core	DS, MO	E2, E5	Apache 2.0
Conformité	RoPA/DPIA/BN/DSAR	TrustArc [R8]	DPO, Legal	E3, E4	Propriétaire
Sécurité	SIEM	Wazuh	DC	P3	GPLv2
Sécurité	Chiffrement & clés	OpenBao	DC	P3	MPL-2.0
Sécurité	Centre IAM (identifiants dynamiques)	OpenBao	DC	P3	MPL-2.0
Gouvernance IA	Catalogage des modèles & lineage des datasets	MLflow	MO	E5	Apache 2.0
Gouvernance IA	Versionage des datasets	DVC	MO	E5	Apache 2.0
Gouvernance IA	Détection des biais	AIF360	MO, MRM	E5	Apache 2.0
Gouvernance IA	Explicabilité	AIX360	MRM	E5	Apache 2.0

Glossaire : Enjeux : [D1] ; Principes : [D21] ; Rôles : [D22] ; Conformité : RoPA = Record of Processing Activities (RGPD, art. 30), DPIA = Data Protection Impact Assessment (RGPD, art. 35), BN = Breach Notification (RGPD, art. 33 & 34), DSAR = Data Subject Access Request (RGPD/CCPA) ; & Sécurité : SIEM = Security Information and Event Management.

3.5. Plan pilote

3.5.1 Périmètre et justification

Périmètre retenu. Les *modèles et données d'entraînement du système de recommandation* (composé éventuellement de plusieurs modèles de ML/IA) au sein du département *Product Development*. Teste simultanément les mécanismes suivants en conditions réelles :

Mécanisme	Enjeu
Rattachement fonctionnel du Data Steward au CDO	E1
Outillage Soda Core (contrôle courant et données d'entraînement)	E2
Rôles Model Owner/Model Risk Manager et circuit de classification-approbation	E5
Déploiement incrémental de Colibra et du RoPA (TrustArc), scopé au périmètre pilote	E1, E3

E3/E4 restent hors périmètre principal : la conformité RGPD globale suppose le déploiement complet de la plateforme, hors pilote — un RoPA scopé à un seul département ne vaut pas conformité article 30.

Objectifs. (1) Valider le rattachement fonctionnel DS-CDO sur un cas réel de décompartmentation. (2) Mesurer l'Engineering overhead réel des Data Custodians — main-d'œuvre uniquement, hors infrastructure et maintenance pluriannuelle. (3) Classifier les modèles testés selon leur niveau d'impact et éprouver le circuit d'approbation sur des versions successives. (4) Trancher les points de vigilance techniques : recouvrement OpenMetadata/Soda Core, suffisance de Soda Core pour E5, charge IAM et détection transférée à Wazuh/OpenBao, fonctionnement du connecteur *Colibra/OpenMetadata*, et synchronisation de groupes via SSO — confirmée pour OpenMetadata et Colibra, non documentée pour TrustArc. (5) Valider la viabilité du déploiement incrémental de Colibra et du RoPA. (6) Vérifier que la population du RoPA dispose d'une classification préalable des données traitées. (7) Conduire la migration de sécurisation obligatoire du stockage initial : régénération des secrets, collecte exhaustive des profils et droits d'accès existants, redéfinition via OpenBao (module AWS Secrets Engine) et l'annuaire d'entreprise partagé.

Équipe. PPM (coordination, reporting DGC) · DS (qualité domaine, double rattachement, glossaire Colibra) · MO (MLflow, AIF360, classification) · MRM (revue, validation, dossier d'approbation) · DO (arbitrage métier) · DC (déploiement technique, migration de sécurisation, Engineering overhead) · DPO/Legal (population du RoPA).

Calendrier (21 semaines).

Jalons	Semaines	Contenu
01-06 (x)	S1-S7	Phase de sécurisation , bloquante : existence d'un annuaire central SAML/OIDC, sécurisation des infrastructures préexistantes, vérification SSO TrustArc et RBAC des autres outils, test d'intégration bout-en-bout, revue de suspension/poursuite
07.1- 07.2	S8-S17	Déploiement technique (4 sem.) et population du RoPA (en parallèle, jusqu'à S17)
08-09	S12-S13	Vérifications de recouvrement Soda Core/OpenMetadata et du connecteur Colibra ; population du glossaire Colibra
10.1- 10.2	S14-S17	Classification du modèle puis exécution en conditions réelles
11-12	S16-S17	Vérification technique intermédiaire et revue intermédiaire
13	S18	Premier passage du circuit d'approbation
14-16	S19-S21	Consolidation, synthèse, clôture

Livrables. Rapport qualité des données · rapport de validation du circuit de classification/approbation · estimation de l'Engineering overhead · note de recouvrement technique (repli Cuallee si besoin) · note de synchronisation catalogage · note de contrôle d'accès (RBAC/SSO) · rapport de migration de sécurisation · rapport de déploiement incrémental Colibra/RoPA · retours des parties prenantes · rapport d'évaluation du double rattachement.

Indicateurs. Trois dimensions DMAT re-cotées (Data Governance, Data Quality : niveau 1→2 ; Analytics & BI/gouvernance IA : niveau 2→3), ancrées à des artefacts datés (logs Soda Core, workflows Collibra, dossiers de classification) plutôt qu'à une impression générale, validées par le DGC au Jalon 16. Le double rattachement est évalué séparément par cinq indicateurs — adoption des standards, délai de propagation, fréquence de sollicitation, cohérence terminologique (captés nativement via Collibra) et autonomie départementale (registre minimal dédié) — combinés au critère négatif de §3.6.1 pour éviter qu'un canal inutilisé passe pour un succès.

Risques. Deux catégories nouvelles, propres à la phase de sécurisation : **suspension sans repli** (absence d'annuaire central, aucun palliatif possible, devient un chantier d'infrastructure séparé ; défaut de sécurisation non corrigeable avant le Jalon 06) et **débordement de planning** (délai de réponse de TrustArc hors du contrôle du projet ; échec du test d'intégration bout-en-bout sans marge pour une seconde itération ; exécution en conditions réelles compressée à 4 semaines, la plus courte de toutes les versions de calendrier envisagées). S'y ajoutent les risques opérationnels : charge des Data Custodians sous-estimée (4 outils sur 10, repli vers l'offre managée Collate) ; collecte incomplète des profils d'accès existants (accès orphelins après bascule vers OpenBao) ; suffisance de Soda Core pour E5 (repli Cuallee) ; dépriorisation à long terme de Soda Core au profit de Soda Cloud (repli TestGen) ; absence de classification préalable des données, condition de la fiabilité du RoPA ; désalignement avec les cycles budgétaires trimestriels lors des transitions inter-département.

Formation. Session dédiée au Data Steward et au Product Manager sur le mécanisme de double rattachement (E6), et sur la répartition entre autorité fonctionnelle (CDO) et organisationnelle (département). Revue finale (Jalon 16) structurée en trois axes : ce qui a fonctionné mieux que prévu, ce qui a nécessité un ajustement, ce qui reste non résolu.

3.6. Feuille de route de généralisation

Conditions de passage à l'échelle. Chaque dispositif reçoit une décision feu vert/orange/rouge, adossée aux KPIs et aux risques du pilote : double rattachement (absence de conflit d'autorité, sinon clarification écrite plutôt qu'abandon) · Soda Core/OpenMetadata (décision au Jalon 08.1) · connecteur Collibra-OpenMetadata (Jalon 09) · Soda Core pour E5 (suffisance jugée entre les Jalons 08.1 et 11, sinon repli Cuallee) · circuit de classification/approbation (délai mesuré au Jalon 13, resserrement des critères si trop lent plutôt qu'allègement du circuit) · déploiement incrémental Collibra/RoPA (extensible sans reconstruction majeure) · Engineering overhead (séquencement pluriannuel si charge intenable) · **phase de sécurisation elle-même** (franchissement du Jalon 06 sans suspension ; un point structurellement bloquant devient un chantier séparé, pas seulement un préalable à la Phase 2).

Séquencement. Le pilote ne couvre qu'un sous-ensemble d'un seul département ; le reste de Product Development et les autres départements de l'organigramme [D22] restent à couvrir, selon un ordre justifié par le niveau de risque et le coût marginal (Marketing en priorité pour E3/E4, Content Curation ensuite pour E2/métadonnées). La phase de sécurisation (Jalons 01-06) ne se reproduit pas aux phases suivantes : l'annuaire central, les rôles OpenBao et les intégrations SSO déjà validés sont étendus, pas reconstruits — seule une migration allégée (régénération des secrets, collecte des profils) est reconduite à chaque nouveau département. D'où une durée canonique de phase réduite pour les phases 2 à 4, et une marge inter-phases renforcée pour absorber le risque d'alignement aux cycles budgétaires trimestriels :

Phase	Périmètre	Durée	Marge	Fin cumulée
1 (pilote)	PD — entraînement recommandation, sécurisation complète	21 semaines (~5 mois)	2 mois	M5
2	PD — reste des activités	3 mois	2 mois	M10
3	Marketing — E1/E3/E4, risque réglementaire le plus élevé	3 mois	2 mois	M15
4	Content Curation — E2, métadonnées	3 mois	—	M20
Consolidation	Ensemble des départements, niveau 3 généralisé	—	—	M22-M24

Ce séquencement atteint la **borne haute** de la fourchette de référence [R11, Q7] (15-24 mois) — un compromis assumé, pas un dépassement silencieux : la rigueur de sécurisation en phase 1 et les marges renforcées entre phases coûtent du temps, jusqu'à la limite de ce que la référence exécutive considère acceptable.

Ajustements attendus au cadre de gouvernance. Intégration formelle de l'amendement de proportionnalité par niveau d'impact — déjà réalisée dans [D21]/[D22] — avec calibration finale des seuils selon les résultats du pilote · révision du tableau d'outils sur les deux lignes explicitement testées (recouvrement Soda Core/OpenMetadata, suffisance pour E5) · établissement d'un coût total de possession complet, au-delà de l'Engineering overhead, une fois un historique d'exploitation suffisant disponible · validation de la couverture DSAR par TrustArc comme exercice séparé, porté par DPO/Legal Team,

avant l'ouverture de la Phase 3, en s'appuyant sur le RoPA déjà peuplé · formalisation en procédure documentée de l'extension légère de sécurisation requise à chaque nouveau département, distincte de la phase complète qui n'a lieu qu'une fois.

Trajectoire de maturité. Niveau 2 sur le périmètre pilote à M5 → niveau 2-3 étendu à tout Product Development (M10) → Compliance et Data Usage via Marketing (M15) → niveau 3 sur Metadata via Content Curation (M20) → niveau 3 généralisé à l'ensemble des départements (M22-M24), conformément à l'objectif fixé en [D21 §2.1.7]. Cette trajectoire reste indicative : chaque jalon de phase est un point de réévaluation, pas un engagement figé, la feuille de route étant elle-même soumise au principe d'amélioration continue qu'elle sert à mettre en œuvre.

Sources

- [R1] Australian Government Data Maturity Assessment Tool (2026)
- [R2] Spotify Business Case
- [R7] Organizational Models Overview
- [R8] Tech Tools Overview
- [R9] Pilot Implementation Template
- [R11] Executive Q&A Guide
- [D1] *Data Maturity Assessment Report*
- [D21] *Data Governance Policy Document*
- [D22] *Roles and Responsibilities Organizational Chart*